PENSE-BÊTE · CONCEPTS RÉSEAU ET ARCHITECTURE

Bitchat : messagerie maillée et sécurité

03-1370 Bitchat - Messagerie hors réseau en maillage Bluetooth, coupures d'internet et limites de sécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'application fonctionne sans internet via un maillage Bluetooth utilisant le protocole BLE pour relayer les messages de proche en proche.
2. Le chiffrement assure la confidentialité persistante pour les sessions directes Noise XX, mais pas pour le courrier différé Noise X ni les enveloppes Nostr.
3. La sécurité est limitée par l'exposition des métadonnées et l'utilisation d'un UUID de service fixe permettant l'identification par un scanner passif.

Bitchat : Origine et diffusion

Notion	À retenir
Origine et diffusion	Publié le **6 juillet 2025** par **Jack Dorsey** ; dépôt GitHub `permissionlesstech/bitchat` créé le **4 juillet 2025**.
Le principe	Messagerie **décentralisée** (sans compte, sans numéro, sans serveur central) utilisant le **maillage Bluetooth** et le protocole **Nostr**.

Fonctionnement technique de Bitchat

Notion	À retenir
Maillage Bluetooth	Rôle **central** et **périphérique** BLE (sans appairage) : relais de paquets, **TTL de 7**, limite à **5 sauts** si réseau dense (> **6 liens**).
Transport Nostr	Utilise **> 440 relais** mondiaux : salons via **geohash** (2 à 7 caractères), trafic via **Tor** (bibliothèque `Arti`), messages privés via **favoris mutuels**.
Chemin message privé	Priorité : 1. **Bluetooth** (session **Noise** établie) ; 2. **Nostr** (clé publique) ; 3. **File d'attente** (système de coursiers).

Le chiffrement et l'identité

Notion	À retenir
Les clés de l'appareil	Deux paires durables : **Curve25519** (échange Noise) et **Ed25519** (signature). Identifiant de pair de **8 octets** via empreinte **SHA-256**.
Les sessions directes en Noise XX	Utilise **Curve25519**, **ChaCha20-Poly1305** et **SHA-256**. Assure **authentification mutuelle** et **confidentialité persistante**. Paquets complétés à tailles fixes (**256**, **512**, **1 024** ou **2 048** octets).
Le courrier différé en Noise X	Scellé vers la **clé statique** du destinataire via **Noise X**. **Pas de confidentialité persistante** : lecture possible si la clé statique est volée.
Les enveloppes privées sur Nostr	Format Bitchat à **3 couches** (**XChaCha20-Poly1305**, **ECDH secp256k1**, **HKDF-SHA256**). **Pas de confidentialité persistante**. Horodatages décalés de **15 minutes** au plus.
Les groupes protégés sur Android	Salons thématiques protégés par **mot de passe** via dérivation **Argon2id** et chiffrement **AES-256-GCM**.

Le stockage et la retransmission

Notion	À retenir
La boîte d'envoi	Message privé sans chemin : conservé **24 heures** max, **100 messages** par destinataire max. Renvoyé à chaque reconnexion. Abandonné après **8 tentatives** sans succès. Stockage **chiffré** sur disque.
Les coursiers	Enveloppe scellée (max **16 ko**, vie **24 heures**) : adressage **16 octets** (change chaque jour). Transport de **texte** uniquement. Budget copies : **4** initial, plafonné à **8** (spray and wait).
L'historique public et les boîtes Nostr	Messages publics : cache de **1 000 paquets** max, synchronisation entre voisins toutes les **15 secondes** environ pendant **6 heures**. Nostr : enveloppes privées sur relais, relecture des **24 dernières heures**.
L'effacement d'urgence	Triple appui : efface **clés d'identité**, **favoris**, **courrier transporté**, **boîte d'envoi**, **historique public** et **compteurs**. Images/vocaux (quota **100 Mo**, durée **7 jours**) : écrits sur disque **sans chiffrement** propre.

Usages lors des crises

Notion	À retenir
Mouvements de contestation	Usage de **Bitchat** lors de blocages (ex: **Népal** en **septembre 2025**, **Ouganda** en **janvier 2026**, **Iran** en **janvier 2026**, **Inde** en **juillet 2026**) ou manifestations (**Indonésie**, **Madagascar**).
Réaction des États	Demandes de restriction (**I4C** contre **GitHub**), menaces d'interdiction, essais de perturbation du **Bluetooth**, hameçonnage ou exploitation des métadonnées (**BISI**). **296** coupures en **54** pays en **2024**.
Cadre français	**Utilisation** de la cryptologie libre (**art. 30 loi du 21 juin 2004**) ; **fourniture et importation** déclarées à l'**ANSSI**. Refus de remettre la convention de déchiffrement puni (**art. 434-15-2 code pénal**). Blocage de **TikTok** en Nouvelle-Calédonie (mai 2024) jugé illégal par le **Conseil d'État** le **1er avril 2025**.

Limites de sécurité de Bitchat

Notion	À retenir
Failles de lancement	Absence de **tests de sécurité** ; attaque de l'homme du milieu possible (authentification défaillante) ; clés **statiques** durant la session ; **dépassement de tampon**.
Métadonnées	Point faible : **identifiant de pair**, **pseudonyme** et **clés publiques** en clair ; **UUID de service Bluetooth** constant ; **TTL** par défaut.
Copies piégées	Versions modifiées invérifiables si le dépôt est inaccessible : elles peuvent enregistrer les messages en clair ou envoyer les clés à un tiers. Vérifier l'intégrité d'une version publiée avec le manifeste `SOURCE-MANIFEST.txt`.
Limites pratiques	Portée **Bluetooth**, **batterie** et densité d'utilisateurs ; risque de saisie d'appareil déverrouillé ou de destinataire compromis.

Pièges et confusions

- ⚠ Confondre la confidentialité persistante disponible en Noise XX avec celle absente en Noise X ou sur Nostr.
- ⚠ Croire que l'identifiant de pair est éphémère alors qu'il dérive de la clé statique.
- ⚠ Penser que le chiffrement protège les métadonnées alors que c'est son point faible.
- ⚠ Confondre le rôle de Tor (anonymisation du trafic Nostr) avec celui du Bluetooth (maillage hors réseau).
- ⚠ Ignorer que le nombre de sauts est réduit à 5 dans un réseau dense au lieu de 7.
- ⚠ Assumer que les images et vocaux sont chiffrés sur le disque alors qu'ils ne possèdent pas de chiffrement propre.

Sigles et définitions

Mesh
: Réseau sans infrastructure où chaque appareil relaie les messages vers ses voisins.

TTL
: Compteur de sauts restants porté par chaque paquet qui diminue à chaque relais.

Confidentialité persistante
: Garantie que le vol d'une clé à long terme ne permet pas de déchiffrer les messages passés.

Geohash
: Code alphanumérique désignant une zone géographique de taille variable.

Panic wipe
: Suppression immédiate des clés, contacts et historiques via un triple appui.

UUID de service
: Identifiant fixe annoncé en Bluetooth permettant de détecter l'usage de l'application.

Auto-test

1. Quelle est la limite maximale de sauts pour un message ?
2. Quel protocole est utilisé pour les sessions privées sur le maillage ?
3. Comment s'appelle la méthode de diffusion utilisant des coursiers avec un budget de copies ?
4. Quel fichier permet de vérifier l'intégrité des fichiers d'une version publiée ?
5. Quelle bibliothèque permet à Bitchat de faire passer son trafic Nostr par Tor ?

Réponses : **1.** 7 sauts. · **2.** Le protocole Noise. · **3.** Le spray and wait. · **4.** SOURCE-MANIFEST.txt. · **5.** Arti.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.